

The Arzens

Governance, Risk & Compliance (GRC) Internship Project

Phase 4

ISO/IEC 27001:2022
Internal Audit Simulation

Audit Executive Summary



Usama Arshad

Governance, Risk & Compliance
(GRC) Internship

Lead: Shahal Farid

Co-Lead: Anas Zeeshan



Fictional Organization:
Kohsar Digital Bank (KDB)

Submission Date:
Monday, August 24, 2026

1. Overview

This Executive Summary presents the results of the control assessment phase of the ISO/IEC 27001:2022 Internal Audit Simulation for Kohsar Digital Bank (KDB). It is based solely on the finalized Phase 4 Nonconformity Report and Corrective Action Recommendations. Each nonconformity described below was concluded from objective, traceable evidence against an established audit criterion — an ISO/IEC 27001:2022 requirement, an Annex A control referenced in KDB's Statement of Applicability (SoA), or a specific requirement in one of KDB's own governing policies.

2. Headline Results

Confirmed Nonconformities	6 (all Minor; 0 Major)
Major Nonconformities	0
Open / Pending Items	8 fully Pending, plus 1 partially pending (A.6.5 HR-notification leg)
Clause 8.1 (Operational Planning & Control)	Conforms — with documented evidence limitations

3. Summary of Confirmed Nonconformities

All six confirmed nonconformities are classified as Minor under the audit's severity methodology: an isolated or limited failure against an established requirement, where the relevant process or control exists and is generally implemented, but a specific instance does not conform. No Major nonconformity — an absence or systemic breakdown of a required process — was identified.

- **NC-01 — Governance & Risk Escalation Flow, Stage 3 SLA:** 2 of 8 sampled escalations exceeded the 3-business-day SLA with no documented exception.
- **NC-02 — A.5.9, Asset Inventory:** 2 asset records lacked required classification information.
- **NC-03 — A.5.15, Access Control:** 2 of 15 sampled de-provisioning tickets breached the 24-hour revocation requirement by 5 and 7 days, tied to a single system migration event.
- **NC-04 — A.6.1, Screening:** Background verification records were missing for 2 of 10 sampled new hires.
- **NC-05 — A.6.8, Event Reporting:** 1 of 12 sampled events breached the 24-hour escalation requirement by 6 hours.
- **NC-06 — A.8.24, Use of Cryptography:** No cryptographic/key-management standard or equivalent documented rules were identified in KDB's available artifact set, although the underlying encryption control is evidenced as implemented and operating for the tested TLS and cloud encryption configurations.

4. Corrective Action Status

A corrective action recommendation has been proposed for each of the six confirmed nonconformities, addressing the specific instance identified and, where supported by evidence, a related contributing factor. Root causes were stated only where directly supported by evidence; when evidence did not establish a cause, this was explicitly noted as requiring KDB management validation rather than an inferred explanation. Proposed corrective action owners are drawn from KDB's own source documents; where the SoA and KDB's Task 9 policies name different roles for the same control, this conflict is disclosed rather than resolved by assumption. No deadlines, thresholds, or SLAs are proposed beyond those already established in KDB's documents, since none are defined in the audit criteria for setting corrective action timeframes.

5. Open Items Requiring KDB Governance Action

Eight items remain fully Pending, and the HR-notification leg of A.6.5 remains partially Pending. These items are not treated as nonconformities because KDB's available source documents do not provide a sufficiently specific and consistently applicable basis for a defensible conclusion. They remain open items for KDB governance action and are not converted into findings in this audit.

- **Clause 6.1.3 (Risk treatment); A.5.19 (Supplier relationships); A.6.3 (Awareness training); A.7.7 (Clear desk/screen); A.8.8 (Vulnerability management); A.8.9 (Configuration management); and A.8.13 (Backup)** — Each remains Pending due to the absence of a KDB-defined threshold, cadence, or scope for the relevant requirement.
- **Clause 7.5 (Documented information)** — Pending due to a genuine, unresolved conflict between KDB's actual policy-approval practice (uniform "CISO" approval in Task 9) and the Governance Charter/Policy Hierarchy's defined approval tiers, which do not define a CISO role.
- **A.6.5 (Responsibilities after termination), HR-notification leg** — Pending; the access-control leg of this control is addressed under NC-03 and is not a separate finding.

KDB management attention is recommended to establish the missing thresholds/criteria for the fully Pending items and to resolve the CISO/Governance Charter role-mapping conflict underlying Clause 7.5 so that these items can be conclusively assessed in a future audit cycle.

6. Overall Conclusion

This audit identified six confirmed Minor Nonconformities, with no Major Nonconformities. Clause 8.1 (Operational Planning and Control) is concluded as Conforms, with documented evidence limitations, consistent with the finalized audit assessment. The remaining Pending items reflect gaps in KDB's established criteria and documentation rather than confirmed control failures and are recorded as open items for KDB governance action rather than nonconformities.

- End of Report -